

EU Exporter TIA 报告草案

TIA 传输影响评估报告

传输背景: ## 第一章 跨境传输场景与角色识别

（一）数据出口方与进口方的GDPR角色确认

根据提供的信息，本次跨境数据传输涉及两方主体。

- 1 数据出口方为“EU Exporter”，其在本次处理活动中的GDPR角色为控制者（controller）。
- 2 数据进口方为“US Importer”，其在本次处理活动中的GDPR角色为处理者（processor）。

上述角色界定是后续适用标准合同条款（SCCs）及评估双方权利义务的基础。根据EDPB建议，识别各方的角色是评估传输合法性的第一步 [1]。

（二）传输场景与数据类别描述

- 1 传输场景：未提供具体的处理活动或业务场景描述。
- 2 传输数据类别与敏感性：本次传输涉及的数据敏感性等级被评估为“中等”（medium），风险系数为1.0。未提供具体的数据类别（如个人数据种类）及详细的处理目的。

鉴于数据敏感性为中等，且传输目的地国家风险较高，有必要对处理操作进行审慎评估，以确定其对数据主体权利与自由可能产生的风险 [1]。

（三）传输目的地与所选法律工具

- 1 第三国（目的地国）：美利坚合众国（United States）。
- 2 所选传输法律工具：标准合同条款（Standard Contractual Clauses, SCCs）。欧盟委员会未就美国做出充分性认定，因此本次传输属于向非充分性认定国家的传输。
- 3 路径判断：由于是使用SCCs向非充分性认定国家进行传输，根据EDPB建议，必须进行完整的传输影响评估（TIA），包括对补充措施的评估。评估路径确认为“fulltiascc”。【待核验：缺少法规依据】

【推测】基于数据出口方为控制者、数据进口方为处理者的角色设定，本次传输很可能采用了欧盟委员会于2021年6月通过的控制者至处理者（Controller to Processor）模块的标准合同条款。

DPO意见: No objection.

传输工具: ## (1) 所选传输工具的法律依据（GDPR第46条）

本次跨境数据传输选用的工具为欧盟委员会通过的标准合同条款（Standard Contractual Clauses, SCCs）。其法律依据为《通用数据保护条例》（GDPR）第46条第

- 1 款(c)项及第
- 2 款。根据该条款，在缺乏充分性认定的情况下，若控制者或处理者提供了适当保障措施，且数据主体享有可执行的权利和有效的法律救济，则可通过有约束力的公司规则或欧盟委员会通过的标准数据保护条款（如SCCs）进行传输 [1]。SCCs作为GDPR第46条认可的传输机制之一，为数据出口方和数据进口方设定了具有法律约束力的合同义务，旨在确保传输至第三国的个人数据保护水平不低于欧盟标准。

(2) 该工具在本传输场景的适用性分析

在本传输场景中，数据出口方（EU Exporter）为控制者，数据进口方（US Importer）为处理者，符合SCCs中模块二（控制者至处理者）的适用条件。因此，从合同主体角色来看，SCCs在形式上是适用的。

然而，根据上下文提供的第三国法律评估，目的地国（美国）的法律框架构成了高风险。具体而言，美国的《外国情报监视法》第702条（FISA Section 702）、第12333号行政命令（EO 12333）以及《云法案》（CLOUD Act）可能为政府访问数据提供途径，并限制有效的救济渠道。这些法律赋予了美国当局广泛的监控和数据访问权力，可能在实际中削弱SCCs合同条款所提供的保障，使其无法在实践中得到遵守。EDPB建议明确指出，

在评估SCCs等工具的适用性时，必须考虑第三国法律对工具有效性的影响 [1]。

鉴于上述高风险，单纯依赖SCCs不足以确保传输的持续合规性。因此，必须采取补充措施以弥补第三国法律环境造成的保护缺口。在本场景中，已识别并计划实施“端到端加密且密钥由欧盟方管理”的技术措施。该措施被评估为充足，能够有效缓解多数政府访问风险，因为它使得数据进口方及第三国当局在无法获取密钥的情况下无法访问明文数据。最终结论指出，SCCs的适用是有条件的，取决于补充措施的有效实施。综合评估后，本次传输的残余风险等级为“中等”。【待核验：缺少法规依据】

(3) 是否存在充分性认定

否。

欧盟委员会未针对美利坚合众国作出充分的保护水平认定（充分性认定）。因此，本次向美国的跨境数据传输不能依据GDPR第45条进行，必须依赖第46条规定的适当保障措施（如本案中的SCCs及补充措施）。

第三国法律分析

(1) 目的地国数据保护法律框架

本次数据传输的目的地国为美利坚合众国。美国未获得欧盟委员会根据《通用数据保护条例》（GDPR）第45条作出的充分性认定。美国缺乏一部全面、与GDPR对等的联邦层面数据保护法律。虽然存在如《加州消费者隐私法》等州级立法，但其适用范围和提供的保护水平与GDPR存在显著差异，且不约束联邦政府的情报监控活动。因此，美国的数据保护法律框架无法为源自欧盟的个人数据提供与欧盟内部实质等同的保护水平。

(2) 政府获取数据的法律基础

美国存在多项允许政府机构，特别是情报机构，为国家安全目的获取个人数据的法律授权，这些授权可能构成大规模监控计划的法律基础，对传输数据的保护构成高风险。具体法律依据包括：

- 1 《外国情报监视法》第702条：该条款授权针对美国境外的非美国人进行无特定目标的情报监控，允许大规模收集通信内容。
- 2 《澄清境外合法使用数据法》：该法案确立了美国执法机构无论数据存储于何处均可通过法律程序获取数据的权力，可能与美国公司的数据披露义务产生冲突。
- 3 第12333号行政命令：该命令为美国情报机构在境外开展监控活动提供了广泛的法律基础，其执行通常不受司法令状约束。

这些法律框架共同构成了美国政府访问传输至其境内的个人数据的广泛权力，且相关程序可能缺乏相称性、必要性保障及有效的事前司法授权。

(3) 数据主体救济途径

对于受美国监控法律影响的非美国公民（包括欧盟数据主体），在美国法律下缺乏有效的救济途径。数据主体通常无法获悉其数据是否被收集，也难以通过美国法院质疑相关监控行为的合法性或寻求损害赔偿。虽然存在如“隐私与公民自由监督委员会”等监督机制，但其主要提供事后审查，且无法为个体提供具有约束力的救济。因此，欧盟数据主体在美国法律体系下难以获得与GDPR第47条要求相符的有效行政和司法救济。

(4) 对SCC有效性的实质影响评估

根据EDPB建议，当第三国法律允许政府以不符合欧盟相称性原则的方式访问数据时，可能“减损”标准合同条款（SCCs）的承诺，使其无法在实践中得到遵守，从而影响SCC作为传输工具的有效性 [1]。本案中，美国的高风险监控法律框架（特别是FISA第702条、CLOUD法案和EO 12333）构成了此类减损风险。这些法律可能迫使数据进口方（US Importer）违反其在SCCs模块二（控制者至处理者）中关于保护数据免受政府访问、通知数据出口方以及挑战非法请求的合同义务。

鉴于已识别的高风险，为确保传输符合GDPR第46条要求，必须实施补充措施。本案中拟议的“端到端加密并由欧盟方管理密钥”是一项强有力的技术措施。只要加密算法足够强健且密钥始终由欧盟数据出口方（EU Ex

porter) 独家控制, 理论上可防止数据进口方及第三国政府访问明文数据, 从而有效缓解政府访问风险。然而, 该措施的有效性取决于其技术实现的完备性及持续运营的合规性。

结论: 在未实施补充措施的情况下, 美国法律对SCCs的有效性构成实质性影响。结合拟议的强加密措施, 本次传输的整体风险等级评估为“中等”。SCCs的效力取决于所采取的补充措施是否持续有效, 因此本次基于SCCs的传输是附条件的。数据控制者(EU Exporter)负有持续监控第三国法律发展及补充措施有效性的责任。

补充措施

第四章 补充措施可执行性评估

(1) 计划采取的补充措施

根据传输场景与风险评估, 为应对美国(第三国)法律框架带来的高风险, 计划采取以下补充措施:

- 1 技术措施: 实施端到端加密(End-to-end encryption), 并由数据出口方(EU Exporter)或其在欧盟的关联实体管理加密密钥(EU-managed keys)。该措施旨在确保数据在传输和静态存储时均被加密, 且解密密钥始终处于欧盟司法管辖区的控制之下。
- 2 合同措施: 在作为传输工具的标准合同条款(SCCs)基础上, 纳入并强化关于技术措施实施、数据进口方义务及违规后果的具体约定。合同将明确禁止数据进口方(US Importer)在未获得数据出口方授权且无有效法律依据(如符合GDPR第48条规定的国际协议)的情况下, 向第三国当局披露加密密钥或解密后的数据。
- 3 组织措施: 建立由数据出口方主导的定期审计与合规监控程序, 以验证数据进口方对加密协议和合同义务的遵守情况。【待核验: 缺少法规依据】

(2) 每项措施能否有效弥补第三国法律不足

本评估的核心在于判断上述措施能否有效应对已识别的第三国法律风险, 即美国《外国情报监视法》第702条(FISA Section 702)、第12333号行政命令(EO 12333)及《云法案》(CLOUD Act)可能授权的政府访问, 以及数据主体救济途径不足的问题 [1]。

技术措施(端到端加密与欧盟密钥管理)的有效性*: 该措施是应对政府访问风险的关键。如果数据在传输和存储过程中始终处于加密状态, 且解密密钥仅由位于欧盟的实体持有, 那么即使数据进口方收到美国当局基于上述法律提出的数据访问要求, 其也无法提供有意义的、可读的个人数据。这在理论上可以阻断基于FISA 702和CLOUD Act的批量监控和数据索取。然而, 其有效性完全取决于加密实施的强度和密钥管理的彻底性。若法律要求直接针对数据进口方, 迫使其削弱加密或交出密钥, 则此措施可能失效。

合同与组织措施的有效性*: 合同措施将技术保护义务具体化、契约化, 并为违约设定了明确后果(如终止合同、索赔), 增强了可执行性。组织措施(审计)是验证技术措施是否持续有效运行的必要手段。然而, 这些措施本身不能直接对抗第三国具有强制力的法律。当美国当局依据其国内法行使权力时, 合同条款可能无法为数据进口方提供有效的抗辩理由。因此, 合同与组织措施主要作为技术措施的支撑与保障, 其弥补法律不足的效力是间接的、辅助性的。

(3) 措施的可执行性和监控机制

为确保补充措施不仅是理论设计而且能在实践中持续有效, 建立以下可执行性与监控框架:

1 技术措施的可执行性与监控:

可执行性*: 数据出口方将负责选择经行业认可的强加密算法与协议, 并直接控制密钥生成、存储和轮换的生命周期。数据进口方的系统访问权限将被配置为无法接触密钥材料。

监控机制*: 通过技术日志监控所有密钥访问和使用尝试。数据出口方将定期(如每季度)进行技术验证, 包括模拟数据恢复流程, 以确认没有未授权的密钥副本存在于美国司法管辖区。

1 合同与组织措施的可执行性与监控:

可执行性*: 将技术措施的具体规范(如加密标准、密钥管理架构图)作为SCCs的附件或附录, 使其成为具有约束力的

最终评估

第五章 剩余风险与合规结论

(1) 实施补充措施后的剩余风险

尽管数据出口方EU Exporter已实施“端到端加密+欧盟密钥管理”作为补充技术措施，本次向美国的数据传输仍存在剩余风险，风险等级为“中等”。

主要剩余风险源于第三国（美国）的法律框架。评估确认，美国的《外国情报监视法》第702条（FISA Section 702）、第12333号行政命令（EO 12333）及《云法案》（CLOUD

Act）可能使政府能够访问传输的数据，并限制数据主体获得有效救济。[1]

这些法律授权的大规模监控计划，可能要求数据进口方US

Importer披露数据，从而与SCCs提供的合同保障产生根本冲突。

虽然补充措施（端到端加密与欧盟管理的密钥）是一项强有力的技术控制，能够有效缓解数据传输及静态存储过程中的政府访问风险，但其无法完全消除所有风险。例如，风险可能存在于数据处理环节（当数据在内存中解密以供处理时），或源于数据进口方被法律强制要求披露加密密钥（尽管密钥由欧盟管理）的可能性。此外，技术措施无法解决美国法律框架下数据主体救济途径可能不足的固有风险。

(2) 是否达到欧盟同等保护水平的结论

基于当前评估，在已实施指定补充措施条件下，本次数据传输有条件地达到了欧盟基本同等的保护水平。

结论的核心前提是所部署的补充措施（端到端加密与欧盟密钥管理）得到持续、有效的实施与维护，且数据进口方US Importer严格遵守SCCs中关于协助数据出口方应对政府访问请求、提供透明度通知等义务。[1] 在此操作框架内，技术措施显著提升了数据被访问的难度，为数据主体权利提供了实质性保障，从而在整体上弥补了第三国法律保护不足的缺陷，使得保护水平与GDPR要求基本相当。

然而，此结论是附条件的，并非绝对。其有效性直接依赖于补充措施的技术完整性与合同义务的履行。任何对补充措施的削弱或第三国法律环境的进一步恶化，都可能动摇此结论。

(3) 建议暂停传输的情形说明

数据出口方EU Exporter作为控制者，负有持续监控传输环境的法律责任。建议在以下情形发生时，立即暂停向美国的数据传输：

- 1 补充措施失效或削弱：例如，加密被禁用、加密密钥的管理权转移至欧盟以外、或发现可能危及加密安全性的重大技术漏洞。
- 2 发生实际访问请求：数据进口方US Importer收到美国当局基于FISA 702、CLOUD Act等法律提出的数据访问请求，且该请求超出了SCCs允许的有限例外情况，或数据出口方认为无法通过现有措施（如法律挑战、透明度通知）确保合规。
- 3 法律环境恶化：有明确的法律变更或司法实践表明，美国政府的监控权力被扩大，或数据主体的救济途径被进一步限制，以至于现有补充措施无法再提供有效保障。
- 4 合同义务违约：数据进口方未能履行SCCs中关于政府访问通知、合作与透明度报告的关键义务，导致数据出口方无法有效监督和保护传输数据。

一旦发生上述情形，数据出口方必须根据GDPR第46条及SCCs的规定，评估是否可能采取额外补救措施。若无法在合理时间内恢复足够的保护水平，则必须终止传输。【待核验：缺少法规依据】

第六章 持续复审与行动计划

(1) TIA定期复审机制

根据EDPB建议，数据传输影响评估（TIA）并非一次性活动，而是一个持续的过程，需要建立定期复审机制，以确保在传输环境发生变化时，所依赖的保障措施（包括SCCs和补充措施）持续有效。[1]

本传输的定期复审应至少每年系统性地进行一次。复审应基于本TIA报告所建立的基准，重点审查以下方面：(a) 第三国（美国）关于政府访问数据的法律与实践是否发生重大变化；(b) 已实施的补充措施（端到端加密与欧盟密钥管理）在技术上的有效性与完整性；(c) 数据进口方（US Importer）对SCCs合同义务的遵守情况及其内部数据安全政策的更新。复审过程应形成书面记录。

(2) 触发重新评估的事件清单

除定期复审外，若发生以下任何事件，数据出口方（EU Exporter）应立即触发对本次数据传输的重新评估：

- 1 第三国法律变化：美国颁布新的法律、法规，或对现有法律（如《外国情报监视法》第702条、CLOUD Act、第12333号行政命令）进行修订或解释，可能增加政府访问传输数据风险或影响现有补救措施的有效性。
- 2 司法或监管决定：欧盟或成员国法院、数据保护机构（DPA），或美国法院作出可能影响SCCs有效性或对本传输合法性判断的裁决。
- 3 补充措施失效：已部署的端到端加密与欧盟密钥管理措施出现重大技术漏洞、被破解，或密钥管理流程出现失控风险。
- 4 数据进口方变更：数据进口方（US Importer）发生控制权变更、破产、或其数据处理实践发生重大变化，可能影响其履行SCCs义务的能力。
- 5 数据处理性质变更：传输数据的类型、敏感度、或处理目的发生重大变化，导致风险状况改变。
- 6 违规事件：发生涉及传输数据的重大安全事件或数据泄露，或发现数据进口方存在系统性违反SCCs合同条款的行为。

(3) 责任人和时间节点

责任人*：数据出口方（EU Exporter）作为数据控制者，对GDPR合规负最终责任，应指定其数据保护官（DPO）或合规部门主导并协调TIA的持续复审与重新评估工作。数据进口方（US Importer）作为数据处理者，有合同义务（基于SCCs）及时向数据出口方通报任何可能影响传输合规性或补充措施有效性的事件，包括上述触发事件。

时间节点*：

定期复审*：应于本TIA报告批准之日起每12个月（或更短周期，若风险状况要求）内完成一次。

事件触发重新评估*：在知悉任何触发事件后的30日内必须启动重新评估程序，并根据事件严重性在合理期限内完成。【待核验：缺少法规依据】

记录保存*：所有复审与重新评估的记录应至少保存至数据传输关系终止后3年，以备监管机构核查。

【待核验：缺少法规依据】

SCC remains conditional on the measures.